TÀI LIỆU API — MẪU 01 — SHILOSKIN

Nguyễn Từ Lân – 23110306 · 25/10/2026 · ShiloSkin v1.0

0. Phạm vi và phiên bản

API 1.0 cho ShiloSkin v1.0. Base URL triển khai: https://sv21.bcse-vju.com/api; cục bộ mặc định http://127.0.0.1:5001/api. Mọi ví dụ dưới đây là dữ liệu demo minh họa contract, không phải số đo/response đã chạy ở VPS. Các route mô tả đúng API của baseline; lỗi quan sát trong bản thực hành phải được báo riêng.

Repo mirror: https://github.com/minhhal1180/shiloskin; tài liệu SRS_23110306 là nguồn expected behavior. Không tích hợp Steam hoặc thanh toán; tất cả price, reference_price, balance đều là SC nguyên.

1. Xác thực và CSRF

POST /login JSON username/password tạo cookie phiên tối đa 8 giờ. Sau login, GET /me lấy user và csrf. Mọi POST/PATCH sau login bắt buộc cookie và header X-CSRF-Token. Không đặt password hoặc CSRF vào URL/log/tài liệu bằng chứng. Cookie HTTPS triển khai phải Secure/HttpOnly/SameSite=Lax; localhost không bật Secure.

Đăng xuất hoặc admin sửa tài khoản làm cookie phiên cũ bị từ chối. API kiểm role/owner/state phía server, không phụ thuộc việc nút đã bị ẩn trên UI.

2. Quy ước dữ liệu và response

Request ghi dùng Content-Type: application/json, object JSON. Không hỗ trợ upload/Steam URL trong MVP. Thành công tạo mới trả201 {id}, cập nhật200 {ok:true}; GET danh sách có items và chi tiết có item. Timestamps ISO8601 UTC; id là số nguyên; active/is_read phản ánh dữ liệu boolean/0..1 theo schema. Body request tối đa1MiB; JSON lớn hơn trả413.

Name/weapon/reason/username trim. Password giữ nguyên khi so hash. Integer không nhận boolean hoặc số thập phân; float phải hữu hạn. Field không được API hỗ trợ không có tác động nghiệp vụ; client chỉ nên gửi field đã mô tả. Không có phân trang trên bộ dữ liệu nhỏ MVP.

3. Kiểu dữ liệu trả về

Type · Các trường

Skin · id:int, name/weapon/rarity/wear:string, float_value:number, reference_price:int SC, active:0/1, created_at/updated_at:ISO8601

InventoryItem · id/item_id:int, skin_id:int, owner_id:int, owner_name/skin_name/weapon/rarity/wear:string, float_value:number, reference_price:int, acquired_at:time, locked:boolean

Listing · id/item_id/skin_id/seller_id:int, buyer_id:int/null, seller_name:string, buyer_name:string/null, price:int, status, moderation_reason, skin metadata, timestamps

Trade · id/proposer_id/recipient_id/give_item_id/want_item_id:int, proposer_name/recipient_name/give_skin_name/want_skin_name:string, status, timestamps

HistoryEvent · id/actor_id/entity_id:int, other_id:int/null, actor_name/action/entity_type/detail:string, created_at:time

Notification · id/recipient_id/entity_id:int, event_type/body/entity_type:string, is_read:0/1, created_at:time

UserAdmin · id:int, username/name/role:string, active:0/1, balance:int SC

Listing statuses: ACTIVE, SOLD, CANCELLED, HIDDEN. Trade statuses: PENDING, ACCEPTED, REJECTED, CANCELLED. Rarity/wear enums xem SRS mục2. /listings công khai theo quyền đọc có lịch sử trạng thái; UI thị trường phải chủ động dùng status=ACTIVE khi muốn chỉ hiển thị tin mua được.

4. Danh mục đầy đủ endpoint

Method · Path sau /api · Quyền · Truy vết · Đầu vào · Response/exception

POST · /login · Không cần phiên · FR-01 · {username:string1..80,password:string1..200} · 200 {ok:true}; cookie phiên. Sai thông tin/khóa:401.

POST · /logout · Cả ba vai trò + CSRF · FR-01 · {} · 200 {ok:true}; thu hồi phiên; cookie cũ gọi /me:401.

GET · /me · Có phiên · FR-01,12 · Không body · 200 {user:{id,username,name,role,balance},csrf:string}. Không trả hash.

GET · /skins · Có phiên · FR-02 · ?q=Redline&weapon=AK-47&rarity=Classified&wear=Field-Tested; q≤200 · 200 {items:Skin[],rarities:string[],wears:string[]}; enum filter sai:400.

GET · /skins/:id · Có phiên · FR-03 · Path id nguyên không âm theo route; dùng ID dương trong client · 200 {item:Skin}; không tồn tại:404.

GET · /inventory · Có phiên · FR-04 · ?user_id=2; bỏ qua để xem kho mình · 200 {items:InventoryItem[],owner:{id,name,username}/null,users:[{id,name,username}]}; user_id sai:400/404 theo FR-04.

GET · /listings · Có phiên · FR-05..07,13 · ?q=Glock&status=ACTIVE&mine=1; status ACTIVE/SOLD/CANCELLED/HIDDEN · 200 {items:Listing[]}; mặc định gồm mọi trạng thái; mine=1 lọc seller hiện tại; q≤200.

POST · /listings · MEMBER + CSRF · FR-05 · {item_id:positiveInteger,price:integer1..100000} · 201 {id}; item người khác:403; khóa/inactive:409; giá sai:400.

POST · /listings/:id/cancel · MEMBER seller + CSRF · FR-06 · {} · 200 {ok:true}; không phải seller:403; không ACTIVE:409.

POST · /listings/:id/buy · MEMBER buyer + CSRF · FR-07,12 · {} · 200 {ok:true,balance:integer}; tự mua/thiếu SC/tin đã kết thúc/chủ thay đổi:409.

POST · /listings/:id/moderate · MODERATOR + CSRF · FR-13 · {reason:string1..1000 sau trim} · 200 {ok:true}; rỗng:400; sai role:403; không ACTIVE:409.

GET · /trades · MEMBER · FR-08..10 · Không body · 200 {items:Trade[]}; chỉ proposer/recipient hiện tại, không toàn hệ thống.

POST · /trades · MEMBER + CSRF · FR-08 · {give_item_id:positiveInteger,want_item_id:positiveInteger} · 201 {id}; sai owner give:403; tự đổi:400; khóa/trùng pending/đối tác không hợp lệ:409.

POST · /trades/:id/action · MEMBER đúng bên + CSRF · FR-09,10 · {action:'accept'/'reject'/'cancel'} · 200 {ok:true,status}; accept/reject chỉ recipient, cancel chỉ proposer; sai bên403; state xung đột409.

GET · /history · Có phiên · FR-11 · Không body · 200 {items:HistoryEvent[]}; actor hoặc other_id hiện tại; không API update/delete.

GET · /notifications · Có phiên · FR-16 · Không body · 200 {items:Notification[]}; chỉ recipient hiện tại.

POST · /notifications/:id/read · Người nhận + CSRF · FR-16 · {} · 200 {ok:true}; is_read=1 bền vững; ID thiếu/của người khác:404.

GET · /users · ADMIN · FR-14 · Không body · 200 {items:UserAdmin[]}; không password_hash/session_version.

PATCH · /users/:id · ADMIN + CSRF · FR-14 · {name?:string1..120,role?:MEMBER/MODERATOR/ADMIN,active?:boolean} · 200 {ok:true}; self khóa/bỏ admin400; role change đang có tin/đề nghị409; thu hồi phiên cũ.

POST · /skins · ADMIN + CSRF · FR-15 · {name,weapon,rarity,wear,float_value,reference_price?:integer,active?:boolean} · 201 {id}; name/weapon1..120, enum hợp lệ, float finite0..1, reference_price1..100000 default100, active defaulttrue.

PATCH · /skins/:id · ADMIN + CSRF · FR-15 · Bất kỳ trường hợp lệ của POST /skins; trường bỏ qua giữ giá trị cũ · 200 {ok:true}; ID thiếu404; sai field400. Không tự tạo inventory.

5. Ví dụ quy trình có thể thử trên database demo mới

5.1. Đăng nhập, kiểm số dư và mua

POST /login với {"username":"member01","password":"Demo@123"}. GET /me lấy csrf. GET /listings?status=ACTIVE: demo mới có tin#1 item5 giá400SC và tin#2 item6 giá2200SC. POST /listings/1/buy gửi {} với cookie/CSRF sẽ chuyển item5 từ member02 sang member01, số dư member01 từ1000 còn600 trong baseline. Đây là ví dụ theo fixture, không khẳng định dữ liệu live hiện chưa bị người khác test.

5.2. Đổi 1:1

Member01 POST /trades {"give_item_id":1,"want_item_id":7}. Member02 đăng nhập bằng context/cookie riêng, GET /trades lấy id rồi POST /trades/:id/action {"action":"accept"}. Baseline chuyển item1 sang member02, item7 sang member01, status ACCEPTED và SC không đổi. Dùng database mới hoặc kiểm lại owner/item trước khi lặp ví dụ.

5.3. Kiểm duyệt

Moderator01 POST /listings/1/moderate {"reason":"Cần kiểm tra mô tả vật phẩm"}. Nếu tin#1 vẫn ACTIVE thì baseline trả200, HIDDEN; nếu người khác đã mua/hủy, trả409. Chỉ MODERATOR được phép, ADMIN không thay vai trò này trên API.

6. Mã lỗi

HTTP · Ý nghĩa · Ví dụ baseline

400 · Validation · price=0/100001/'abc', float=-0.01/1.01, name trống, reason trống, enum/action sai

401 · Không có phiên hợp lệ · Sai password, tài khoản khóa, session hết hạn/đã logout

403 · Sai quyền/owner/CSRF · MEMBER gọi /users; seller hủy tin người khác; proposer accept trade; thiếu token

404 · Không có entity hoặc không thuộc tập được thấy · Skin/listing/trade ID thiếu; notification người khác

405 · Method không được route hỗ trợ · PATCH /history hoặc DELETE /notifications

409 · Xung đột state/điều kiện · Tự mua, thiếu SC, mua SOLD, accept REJECTED, hai giao dịch cạnh tranh, item locked

413 · Body quá lớn · JSON vượt1MiB

500 · Lỗi hệ thống · Không là expected cho input/ID thiếu ở NFR-08; kiểm tra /me/list tiếp sau để xác nhận process còn sống

Error JSON có dạng {"error":"Thông báo tiếng Việt"}; không đưa traceback. Các validation được thực hiện trong transaction, lỗi không để lại item/balance/trade bị thay đổi một phần.

7. Retry và đồng thời

Client có thể gửi Idempotency-Key tối đa100ký tự cho POST/PATCH sau login. Cùng user/method/path/key và cùng raw body trả response đã lưu, không tái chạy nghiệp vụ. Cùng key nhưng body khác trả409. Mỗi thao tác mới dùng key mới. Chưa có lịch tự dọn bảng key trong MVP. Chưa cung cấp key hoặc thay key không được coi là retry cùng thao tác; state/unique constraint vẫn ngăn chuyển một item hai lần.

SQLite BEGIN IMMEDIATE bao quanh thao tác ghi, khóa ngắn và điều kiện state/owner bảo vệ mua và đổi. Hai request cạnh tranh phải đọc lại dữ liệu đã commit của request trước. Không giả lập swap bằng hai lời gọi API độc lập.

8. Tài khoản demo và trách nhiệm

member01/member02: MEMBER; moderator01: MODERATOR; admin: ADMIN; mật khẩu demo chung Demo@123. Dùng context/incognito khác nhau khi thử hai bên. Không gửi dữ liệu cá nhân hoặc tài sản thật. Chủ hệ thống và tester cần tự đối chiếu contract trước khi ký; Codex hỗ trợ cả hai ứng dụng, không thay thế kiểm thử chéo và xác nhận của sinh viên.